

Unit 3: Mobile, Wireless, and IoT Security

Mobile Security:-

Mobile security focuses on protecting smartphones, apps, and mobile data from attacks.

1. Android and iOS Security Models

Mobile security focuses on protecting smartphones and tablets from malware, unauthorized access, data leakage, and network attacks. Both platforms share the **CIA Triad** goals: Confidentiality, Integrity, and Availability.

A. Android Security Model (Open/Flexible Ecosystem)

Android prioritizes hardware diversity and user flexibility.

- **Linux Kernel:** Provides foundational process isolation and user-based permissions.
- **SELinux (Security-Enhanced Linux):** This is a core system that strictly controls app actions using **Mandatory Access Control (MAC)**, ensuring that even if an app is compromised, its impact is contained
- **Application Sandboxing:** Each app runs in its own sandbox with a unique **User ID (UID)**, preventing it from accessing other apps' data.
- **Hardware Root of Trust:** Uses dedicated secure chips like **Titan M2** (Pixel), **Knox Vault** (Samsung), or **StrongBox** to protect encryption keys, fingerprints, and passwords independently of the OS.
- **Trust Model:** Follows an "**Informed Consent**" model where the OS warns users of risks but allows them to "Install Anyway" (Treating users like adults).

B. iOS Security Model (Closed/Walled Garden Ecosystem)

iOS focuses on a tightly controlled, vertical ecosystem.

- **Darwin (XNU) Kernel:** Provides strict process isolation and system security management.
- **Secure Boot Chain:** Ensures only trusted, Apple-signed code runs during startup to prevent OS modifications.
- **Secure Enclave:** A dedicated hardware security processor that stores biometric data (Face ID/Touch ID) and manages encryption keys.
- **Code Signing:** All apps must be digitally signed by Apple; unsigned or tampered apps cannot execute.
- **Trust Model:** Follows a "**Walled Garden**" philosophy where apps must come from the official App Store; there is no "Install Anyway" option for unverified software.

2. Mobile App Vulnerabilities and Permissions

A. OWASP Mobile Top 10 Vulnerabilities

Code	Vulnerability	Impact / Risk
M1	Improper Credential Usage	Hardcoded API keys or weak passwords leading to backend misuse.
M2	Insecure Data Storage	Sensitive tokens stored without encryption in SharedPreferences or files.
M3	Insecure Authentication	Broken login or session handling (e.g., no token expiry) leading to account takeover.
M5	Insecure Communication	Improper TLS or lack of SSL pinning, enabling Man-in-the-Middle (MITM) attacks.
M7	Inadequate Binary Protection	Lack of obfuscation allowing easy reverse engineering and secret extraction.

B. Permission Security Principles

Permissions are the first line of defense, defining what an app is allowed to access.

- **Principle of Least Privilege:** Request only the absolute minimum permissions required.
- **Just-in-Time (JIT) Permissions:** Ask for access only at the moment the feature is needed.
- **Permission Priming:** Explain the necessity of the permission before the OS prompt appears.
- **Graceful Degradation:** The app should remain functional with limited features if a user denies a permission.

3. Mobile Malware and Smishing

A. Mobile Malware Taxonomy

Mobile malware is malicious software designed to steal information, monitor users, or lock devices.

- **Trojans:** Disguised as legitimate apps to gain Remote Access (RATs) to cameras or microphones.
- **Spyware/Stalkerware:** Secretly monitors activities, GPS location, and chats (e.g., **mSpy**).
- **Ransomware:** Locks the device or data until a payment is made.

B. Smishing (SMS Phishing)

Smishing is a phishing attack conducted via SMS or WhatsApp.

- **Goal:** To steal OTPs, bank details, or passwords by providing malicious links.
- **Common Tactics:** Fake bank alerts, lottery messages, or urgent KYC updates.

4. Secure Mobile App Development Basics

Definition: Secure Mobile App Development is the practice of integrating security protocols throughout the Software Development Lifecycle (SDLC) to protect user data, device integrity, and backend infrastructure from sophisticated cyber threats.

1. Secure Communication and Transport Layer Security

All data transmitted between the mobile application and the backend server must be protected against interception.

- **Mandatory TLS:** Apps must use HTTPS (TLS) for all network traffic to prevent **Man-in-the-Middle (MITM)** attacks and session hijacking.
- **SSL Pinning:** Developers should implement Certificate Pinning to ensure the app only communicates with specific, trusted servers, mitigating the risk of compromised Certificate Authorities.
- **M5 Vulnerability Mitigation:** Failure to secure communication is categorized as **OWASP M5**, which is a primary target for attackers using tools like **Burp Suite**.

2. Cryptographic Protection of Data

Sensitive data must be protected in all states—at rest and in transit.

- **Data at Rest:** Information such as tokens, banking details, and personal data should never be stored in plain text.

- **Platform-Specific Secure Storage:** Developers must utilize hardware-backed storage: Android developers should use the **Android Keystore**, while iOS developers must use the **Keychain** and **Secure Enclave**.
- **M2 Mitigation:** Insecure storage (OWASP M2) often occurs when developers leave tokens in SharedPreferences (Android) or Plist files (iOS) without encryption.

3. Robust Authentication and Authorization Frameworks

Ensuring that only legitimate users can access resources is critical to preventing account takeover.

- **Multi-Factor Authentication (MFA):** Essential for 2026 defense strategies to verify user identity beyond just passwords.
- **Token-Based Sessions:** Use secure mechanisms like **OAuth 2.0** or **JWT** with short-lived expiration periods to prevent session reuse.
- **M3 Mitigation:** Insecure Authentication (OWASP M3) is often caused by broken login handling or a lack of session timeouts.

4. Binary Protection and Anti-Reverse Engineering

Attackers often attempt to decompile apps to find hidden backdoors or API keys.

- **Code Obfuscation:** Use tools like **ProGuard** or **R8** to make the source code unreadable to humans, protecting the intellectual property and logic of the app.
- **Avoid Hardcoded Secrets:** Developers must never hardcode API keys or credentials directly in the code (OWASP M1), as these are easily extracted through reverse engineering.
- **Root/Jailbreak Detection:** Implement checks to ensure the app is not running on a compromised device, which bypasses standard OS security models.

5. Input Validation and API Security

The app must never trust data provided by the user or external sources.

- **Input Sanitization:** Validate all inputs to prevent **SQL Injection** and **Cross-Site Scripting (XSS)**.
- **Server-Side Validation:** Security checks must be performed on the backend, as client-side validation can be bypassed by attackers.

- **M4 Mitigation:** Insufficient input validation (OWASP M4) leads to unauthorized data manipulation or system compromise.

6. Supply Chain and Third-Party Security

Modern apps rely heavily on external libraries and SDKs.

- **SDK Auditing:** Developers must vet third-party advertising or utility SDKs to ensure they do not secretly collect user data or create backdoors.
- **M6 Mitigation:** Inadequate Supply Chain Security (OWASP M6) is a rising threat where a single compromised library can affect millions of users.

7. Continuous Security Testing and Analysis

Security is an ongoing process that requires specialized tools.

- **Static Analysis (SAST):** Reviewing code without executing it to find vulnerabilities.
- **Dynamic Analysis (DAST):** Testing the app in a runtime environment to monitor behavior.
- **Standard Tools:**
 - **MobSF:** Automated framework for both static and dynamic analysis of APK/IPA files.
 - **Frida:** Dynamic instrumentation tool to inspect and modify app behavior during runtime.

Conclusion

Secure mobile app development requires a **Defense-in-Depth** approach. By combining hardware-backed security (Root of Trust), rigorous permission principles (Least Privilege), and continuous vulnerability testing (OWASP standards), developers can build resilient applications that withstand modern mobile threats.

5. Mobile Device Management (MDM)

Mobile Device Management (MDM) is an enterprise security solution used by organizations to centrally monitor, manage, and secure mobile devices such as smartphones, tablets, and laptops. It acts as a centralized administrative console to enforce security policies, protect corporate data, and ensure compliance in environments like **BYOD (Bring Your Own Device)**.

I. Need for MDM and Security Goals

Organizations implement MDM to address specific security risks:

- **Data Protection:** Prevents the leakage of sensitive business data.
- **Policy Standardization:** Enforces uniform security settings, such as password complexity, across all devices.
- **Threat Mitigation:** Controls application installations to prevent the spread of **Mobile Malware** like banking Trojans or spyware.
- **Loss Recovery:** Manages the high risk of physical theft or loss associated with mobile hardware.

II. How MDM Operates (Architectural Workflow)

The MDM system functions through a client-server architecture:

1. **Device Enrollment:** The hardware is registered within the organizational network.
2. **Agent Installation:** A dedicated MDM agent/application is installed on the device.
3. **Connection:** The device establishes a secure link with the central MDM server.
4. **Policy Push:** The administrator pushes security configurations (Wi-Fi, VPN, email) directly to the device.
5. **Continuous Monitoring:** The admin monitors compliance and device status remotely.

III. Key Features and Technical Functions

- **Device Configuration:** Automated setup of corporate Wi-Fi, VPN, and secure email settings.
- **Policy Enforcement:** Forces the use of strong passcodes and device encryption. It can also restrict hardware features like the camera or USB ports to prevent data exfiltration.
- **Remote Lock & Wipe:** In the event of a security breach or lost device, administrators can remotely lock the UI or trigger a "Wipe" to erase all corporate data.
- **Application Management (MAM):** Admins can whitelist trusted apps and block unauthorized third-party stores or sideloaded APKs.
- **Containerization:** Technically separates personal data from work data, ensuring that corporate documents cannot be shared via personal messaging apps

IV. Security Benefits vs. Challenges

Security Benefits	Implementation Challenges
Prevents unauthorized access and data leakage.	Privacy Concerns: Employees may worry about personal data tracking in BYOD models.
Ensures regulatory compliance.	User Resistance: Complex security policies can frustrate employees.
Reduces insider threats through centralized control.	Cost & Compatibility: High cost of implementation and issues with different OS versions.

V. Industry-Standard MDM Solutions

Standard tools used in the industry to manage mobile security include:

- **Microsoft Intune**
- **VMware (Workspace ONE)**
- **IBM (MaaS360)**
- **Cisco (Meraki Systems Manager)**

MDM is an essential pillar of modern **Mobile and Wireless Security**. By integrating device-level controls with **Hardware Roots of Trust** (like **Titan M2** or **Secure Enclave**), it ensures that corporate data remains secure even if the underlying device is compromised or lost.

Wireless Security

Wireless security protocols have evolved to address severe vulnerabilities, moving from broken legacy systems (WEP) to modern, robust encryption (WPA3). WEP and WPA are insecure; WPA2 remains common but vulnerable to key reinstatement (KRACK) attacks. WPA3 offers the strongest security, replacing WPA2's four-way handshake with the Dragonfly handshake (SAE

WEP, WPA, WPA2, and WPA3 are Wi-Fi security protocols that encrypt wireless connections. They keep your data hidden and secure your communications while blocking hackers from your network. Generally, WPA3 is the best choice, though it isn't available on all devices. Learn more about Wi-Fi security, then download Avast SecureLineVPN to add an extra layer of encryption.

All Wi-Fi security protocols are certified by the Wi-Fi Alliance, the non-profit organization that owns the Wi-Fi trademark. There are four wireless security protocols:

- Wired Equivalent Privacy (WEP)
- Wi-Fi Protected Access (WPA)
- Wi-Fi Protected Access 2 (WPA2)
- Wi-Fi Protected Access 3 (WPA3)



What are Wi-Fi encryption tools?

Wi-Fi encryption tools help defend your data and your device when you're using Wi-Fi networks. Unsecured wireless networks can be riddled with potential security vulnerabilities that hackers and other cybercriminals can exploit for data breaches or malware attacks.

While Wi-Fi security protocols like WPA2 and WPA3 secure your local network by encrypting the connection itself, a VPN (virtual private network) adds another layer by encrypting all your internet traffic and routing it through a secure server. This hides your activity from your ISP, hackers, and other snoops, while also protecting you on public Wi-Fi and helping to unblock websites for broader content access.

When combined, Wi-Fi security protocols and a robust VPN create a powerful shield that keeps your data private and secure — whether you're at home, on public Wi-Fi, or traveling abroad.

WEP (Wired Equivalent Privacy):-

WEP, which stands for Wired Equivalent Privacy, is the oldest Wi-Fi security protocol and is now considered obsolete. It was the privacy component established in [IEEE 802.11](#), a set of technical standards that aimed to provide a wireless local area network (WLAN) with a comparable level of security to a wired local area network (LAN).

The Wi-Fi Alliance ratified WEP as a security standard in 1999. Once touted to offer the same security benefits as a wired connection, **WEP has been plagued by issues** such as cryptographic flaws in the RC4 algorithm and vulnerability to attacks due to keys being recycled to save space.

Despite efforts to improve WEP, it remains fundamentally insecure and vulnerable to [security breaches](#). As modern computing power has increased, cracking WEP's encryption has become very simple.

WPA (Wi-Fi Protected Access):-

WPA (Wi-Fi Protected Access) is a wireless security protocol released in 2003 to address the growing vulnerabilities of its predecessor, WEP. **The WPA Wi-Fi protocol is more secure than WEP because it uses a 256-bit key encryption** — a major upgrade from the 64-bit and 128-bit keys used by the WEP system. Put simply, a 256-bit key means there are so many possible combinations, it would take millions of years to crack.

WPA also uses the Temporal Key Integrity Protocol (TKIP), which dynamically generates a new key for each network packet, or unit of data. TKIP is much more secure than the fixed-key system used by WEP.

Still, WPA is not without flaws. TKIP, the core component of WPA, was designed to be implemented within WEP-enabled systems via firmware updates. This resulted in WPA still relying on easily [exploitable](#) elements.

WPA2

WPA2 (Wi-Fi Protected Access 2) is the second generation of the Wi-Fi Protected Access wireless security protocol. **WPA2 encrypts your wireless traffic and limits access to those with your network password.**

A benefit of the WPA2 system was that it introduced the [Advanced Encryption System \(AES\)](#) to replace the more vulnerable TKIP system used in the original WPA protocol. AES is a robust encryption standard, relied on by governments, financial institutions, and global enterprises for its strong security.

While WPA2 is secure, some older routers still support WEP/WPA. If WEP/WPA are enabled, it can create a security loophole. To eliminate this threat, **disable WEP/WPA on devices that work with WPA2** and upgrade any devices that rely solely on WEP. You should be able to do this in your router's wireless security settings.

WPA3

WPA3 (Wi-Fi Protected Access 3) is the newest wireless security protocol, designed to encrypt data more securely and protect past sessions, even if a password is later compromised — a feature known as **Perfect Forward Secrecy**. WPA3 is even more secure than its predecessor, WPA2.

WPA3 relies on AES-GCMP (Galois/Counter Mode Protocol), a high-performance encryption mode that boosts both security and speed. Compared with the AES-CCMP mode used in WPA2, **GCMP provides better data integrity and overall efficiency**.

That said, while adoption has increased with newer devices, WPA3 still isn't universal. Many older devices don't support it, and enabling the protocol may require new hardware, which can make the transition costly.

Comparison of Wi-Fi Security Protocols

Protocol	Release Year	Encryption Algorithm	Key Management Handshake	Security Status
WEP	1999	RC4 (64/128-bit)	Static/Fixed keys	Obsolete/Insecure
WPA	2003	TKIP (256-bit)	Dynamic key generation	Insecure
WPA2	2004	AES-CCMP	4-way Handshake	Common but Vulnerable
WPA3	2018	AES-GCMP	Dragonfly Handshake (SAE)	Strongest/Modern

Wireless Network Attacks

Wireless network attacks are deliberate and malicious actions aimed at exploiting vulnerabilities in wireless communication systems to gain unauthorized access, intercept sensitive data, disrupt network operations, or compromise the security of devices and users connected to the network.

These attacks target weaknesses in the protocols, configurations, or encryption mechanisms of wireless networks, taking advantage of their inherent nature of broadcasting signals over the airwaves.

Types of Wireless Network Attacks

Wireless networks have undoubtedly revolutionized the way we communicate and conduct business, offering unparalleled convenience and mobility. However, with this freedom comes the lurking threat of malicious attackers seeking to exploit the vulnerabilities inherent in wireless technology. Here are some of the common types of wireless network attacks:

1. Wireless Eavesdropping (Passive Attacks)

Attackers use tools like packet sniffers to intercept and monitor wireless communications between devices. By capturing data packets transmitted over the air, they can potentially obtain sensitive information, such as login credentials, financial data, or personal information.

2. Wireless Spoofing (Man-in-the-Middle Attacks)

In these attacks, the attacker positions themselves between the wireless client and the legitimate access point, intercepting and manipulating data transmissions. The attacker may then relay the information back and forth, making it appear as if they are the legitimate access point. This enables them to snoop on data or perform other malicious actions unnoticed.

3. Wireless Jamming (Denial-of-Service Attacks)

Attackers flood the wireless frequency spectrum with interference signals, disrupting legitimate communications between devices and access points. By creating excessive noise, they can render the wireless network unusable for legitimate users.

4. Rogue Access Points

Attackers set up unauthorized access points, mimicking legitimate ones, to deceive users into connecting to them. Once connected, the attacker can eavesdrop, capture data, or launch further attacks on the unsuspecting users.

5. Brute-Force Attacks

Attackers try various combinations of passwords or encryption keys in rapid succession until they find the correct one to gain unauthorized access to the wireless network.

6. WEP/WPA Cracking

Attackers exploit vulnerabilities in older wireless security protocols like Wired Equivalent Privacy (WEP) and Wi-Fi Protected Access (WPA) to gain unauthorized access to encrypted wireless networks.

7. Evil Twin Attacks

Attackers create fake access points with names similar to legitimate ones, tricking users into connecting to the malicious network. Once connected, the attacker can intercept sensitive data or execute further attacks.

8. Deauthentication/Disassociation Attacks

Attackers send forged deauthentication or disassociation frames to wireless devices, forcing them to disconnect from the network, leading to service disruptions or potential vulnerabilities when devices automatically reconnect.

9. **War driving** is the act of searching for, mapping, and exploiting unsecured or weak Wi-Fi networks from a moving vehicle using a laptop, GPS, and antenna

Purpose: Primarily used to identify vulnerable home or business Wi-Fi networks to gain free internet access or steal personal data

Wireless Network Defenses

To protect wireless networks from attacks, the following security measures should be implemented:

- Use **WPA3 or WPA2-AES encryption**
- Change **default router username and password**
- Disable **WPS (Wi-Fi Protected Setup)**
- Use **strong and complex Wi-Fi passwords**
- Enable **MAC address filtering**
- Regularly **update router firmware**
- Use **network monitoring tools to detect rogue access points**
- Use **VPN when connecting to public Wi-Fi**

Bluetooth security

Bluetooth security protects short-range wireless communication through authentication, authorization, and encryption. While it offers robust built-in features, risks often arise from improper implementation and default settings.

Core Security Mechanisms

- **Authentication:** Verifies the identity of connecting devices using a challenge-response strategy to ensure you are connecting to the intended device.
- **Authorization:** Determines which services a device is permitted to access (e.g., a headset might access audio but not your contact list).
- **Encryption:** Protects data confidentiality by scrambling transmissions, typically using **AES-CCM** for modern devices.

- **Pairing & Bonding:** The initial process of exchanging secret keys to establish a trusted relationship for future automatic connections.

Bluetooth Security Modes

Mode	Description	Security Level
Mode 1	Non-secure; no authentication or encryption.	None
Mode 2	Service-level security initiated after the link is established.	Medium
Mode 3	Link-level security initiated <i>before</i> the physical link is established.	High
Mode 4	Introduced in Bluetooth v2.1; uses Secure Simple Pairing (SSP) with ECDH for stronger key exchange.	Strongest

Common Security Threats

- **Bluejacking:** Sending unsolicited messages or "vCards" to nearby devices, often used for phishing.
- **Bluesnarfing:** Unauthorized access to data (contacts, messages, files) on a Bluetooth-enabled device.
- **Bluebugging:** Gaining full backdoor control over a device to make calls or send texts without the owner's knowledge.
- **Man-in-the-Middle (MitM):** Intercepting and potentially altering the communication between two paired devices.
- **Denial of Service (DoS):** Overwhelming a device with malformed data packets to crash it or drain its battery.

Best Practices for Users

- **Disable When Not In Use:** Turn off Bluetooth to eliminate the attack surface when you don't need it.
- **Use Hidden Mode:** Set your device to "**Undiscoverable**" so it cannot be found by unknown scanners.
- **Secure Pairing:** Perform pairing only in private, trusted locations to prevent eavesdropping on the initial key exchange.
- **Update Regularly:** Install the latest firmware and security patches from manufacturers to fix known protocol vulnerabilities.

Unpair Unused Devices: Regularly clear your list of "trusted" devices and unpair from rental cars or shared equipment before returning them.

Securing wireless networks

Securing wireless networks requires a multi-layered approach: enabling **WPA3** (or WPA2-AES) encryption, changing default administrator passwords, disabling remote management, and updating firmware regularly. Key strategies include using strong, unique Wi-Fi passwords, hiding or renaming SSIDs, and using guest networks for IoT devices.

Core Components of Wireless Security

- **Encryption (Data Protection):** Scrambles data to prevent unauthorized eavesdropping. **WPA3** is the most secure protocol, followed by WPA2.
- **Authentication (Access Control):** Verifies users and devices. Use strong passwords or Enterprise-level (802.1X/EAP) authentication.
- **Infrastructure Security:** Protects the physical router/Access Point (AP).

Best Practices for Securing Networks

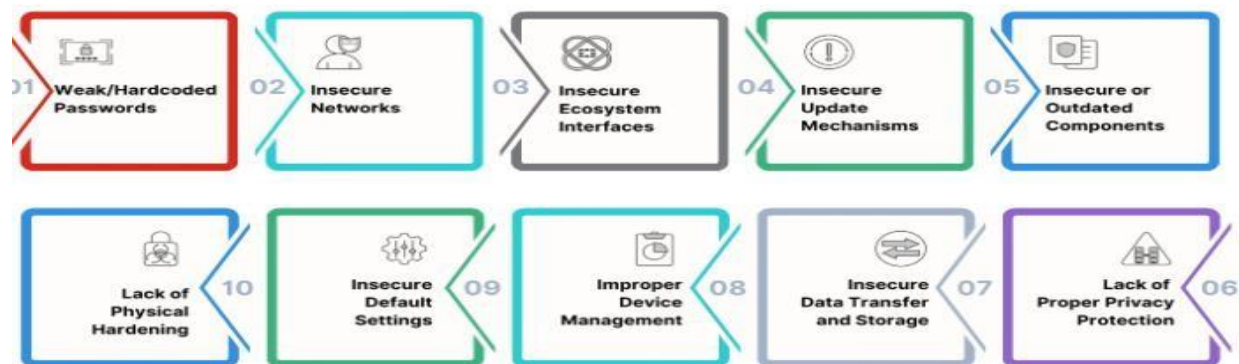
- **Enable WPA3/WPA2:** Never use WEP, which is insecure.
- **Change Default Credentials:** Change the default router admin username and password immediately to prevent unauthorized configuration changes.
- **Update Firmware:** Regularly patch router firmware to fix vulnerabilities.
- **Use Strong Encryption Keys:** Utilize long, complex, random passphrases for the Wi-Fi network.
- **Disable WPS and Remote Management:** Wi-Fi Protected Setup (WPS) is vulnerable. Disable remote management to block outside access to configuration settings.

- **Network Segmentation:** Use a guest network for guests and IoT devices to isolate them from primary, sensitive, or personal devices.
- **Disable SSID Broadcasting (Optional):** Hiding the Service Set Identifier (SSID) makes the network less visible, though it does not prevent dedicated attackers.
- **Use a Firewall:** Enable firewalls on the router and individual client devices.
- **Monitor Network Activity:** Frequently audit connected devices and check for unauthorized, or "rogue," access points.

IoT Security

COMMON IOT VULNERABILITIES

Top IoT Device Vulnerabilities



1. Weak/hardcoded passwords

Weak or hardcoded passwords are among the most frequent methods attackers use to compromise IoT devices. Weak and reused passwords, which are short or easy to guess, are simple for attackers to crack, which they then use to compromise devices and launch large-scale attacks.

2. Insecure networks

Insecure networks make it easy for cyber criminals to exploit weaknesses in the protocols and services that run on IoT devices. Once they have exploited a network, attackers can breach confidential or sensitive data that travels between user devices and the server. Insecure networks are particularly susceptible to **man-in-the-middle (MITM) attacks**, which aim to steal credentials and authenticate devices as part of broader cyberattacks.

3. Insecure ecosystem interfaces

Insecure ecosystem interfaces, such as application programming interfaces (APIs) and mobile and web applications, allow attackers to compromise a device. Organizations need to implement **authentication and authorization processes** that validate users and protect their cloud and mobile interfaces. Practical identity tools help the server differentiate valid devices from malicious users.

4. insecure update mechanisms

Devices with insecure update processes risk installing malicious or unauthorized code, firmware, and software. Corrupt updates can compromise IoT devices, which could be critical for organizations in the energy, healthcare, and industrial sectors. Updates need to be secure and on encrypted channels, while all software must be validated and approved.

5. Insecure or outdated components

The IoT ecosystem can be compromised by code and software vulnerabilities and legacy systems. Using insecure or outdated components, such as open-source code or third-party software, can present vulnerabilities that expand an organization's **attack surface**.

6. Lack of proper privacy protection

IoT devices often collect personal data that organizations need to securely store and process to comply with various data privacy regulations. Failing to protect this data can lead them open to fines, a loss of reputation, and lost business. Failing to implement sufficient security can lead to **data leaks** that jeopardize user privacy.

7. Insecure data transfer and storage

Data that IoT devices receive or transmit across networks needs to be secured and restricted from unauthorized users. This is critical to maintaining the integrity and reliability of IoT applications and organizations' decision-making processes.

8. Improper device management

Failing to manage devices properly throughout their lifecycle leaves them open to vulnerability exploitation, even if they are no longer in use. Businesses need to understand which assets or devices are connected to their networks and manage them properly. Unauthorized or inactive devices can provide attackers with access to corporate networks, enabling them to steal or intercept sensitive data. This makes the discovery and identification of IoT devices crucial to monitoring and protecting devices.

9. Insecure default settings

IoT devices, like personal devices, ship with default and hardcoded settings that enable simple setup. However, these default settings are highly insecure and easy for attackers to breach. Once compromised, hackers can exploit vulnerabilities in a device’s firmware and launch broader attacks against companies.

10. Lack of physical hardening

The nature of IoT devices sees them deployed in remote environments instead of controlled situations that are easy to manage. This makes them easier for attackers to target and disrupt, manipulate, or sabotage.

DEFAULT CREDENTIAL RISKS

Default credential risks remain the **top vulnerability** in IoT security according to the OWASP IoT Top 10. These risks arise because manufacturers often ship devices with identical, publicly documented usernames and passwords (e.g., "admin/admin") to simplify initial setup.

- **Botnet Recruitment:** Compromised devices are frequently enrolled into massive botnets like **Mirai** or **Aisuru/TurboMirai** to launch large-scale Distributed Denial of Service (DDoS) attacks.
- **Network Gateway Exploitation:** Attackers use vulnerable IoT devices as "stepping stones" to move laterally into more secure corporate or home networks.
- **Automated Brute-Force Attacks:** Hackers use automated scripts and tools like **Hydra** to scan the internet and rapidly test thousands of devices against known default lists.
- **Industrial & Safety Hazards:** In manufacturing or healthcare, compromised sensors can lead to production downtime, equipment damage, or even physical safety risks for patients.
- **Data & Privacy Breaches:** Unsecured access allows attackers to monitor traffic, steal sensitive personal data (e.g., health metrics, location), or spy via cameras.

Common Default Credential Types

Type	Description	Examples
Universal Defaults	The same password used for every unit of a specific model.	admin, 1234, password
Blank Passwords	Systems shipped with no password requirement at all.	D-Link Cameras, MySQL
Hardcoded Credentials	Passwords embedded in the device's source code that cannot be changed.	root, guest

Mitigation and Compliance

- **Regulatory Bans:** The UK’s PSTI Act (2024) has banned universal default passwords on smart devices.

- **Unique-per-Device:** Standards like ETSI EN 303 645 require that any pre-installed passwords be unique per device and generated randomly.
- **Enforced Changes:** Many modern systems now force a password change during the initial setup before the device becomes operational.
- **Network Segmentation:** Isolating IoT devices on separate VLANs ensures that even if one is compromised via default credentials, the rest of the network remains protected.

SECURING SMART DEVICES

The Internet of Things (IoT) is transforming our routines and work environments through the integration of technology into various aspects of our lives. IoT devices like fridges and linked thermostats have become commonplace items that add comfort and boost multitasking. However, the spread of these gadgets in homes and offices has seen the protection of their security become a top issue. Ensuring your IoT devices are secure against hacks remains a significant worry for individuals leveraging this technology.

Cyber attackers frequently focus on devices due to their inadequate security measures—seeking out weaknesses to manipulate for nefarious intentions like data theft or initiating a Distributed Denial of Service (DDoS) attack. The significance of ensuring security remains crucial as incidents of cybercrime escalate on a worldwide scale.

10 Tips to Secure Your IoT Devices from Hackers

1. Make Sure to Create a Strong and Unique Password

Protecting your IoT device starts with establishing password security measures as the cornerstone of defense against potential breaches by cyber attackers who often exploit weak passwords. Therefore it is essential to use secure and distinct passwords for every device you own.

Hackers frequently take advantage of default and easily guessed passwords to gain entry to your devices and sensitive information. A reliable password serves as the barrier against entry and plays a crucial role in safeguarding your IoT gadgets connected to your home network effectively.

- To secure IoT devices, try using passwords with a length of 12 to 16 characters as they're generally more secure due to their increased length.
- Create a blend of capital and lowercase letters along with numbers and symbols to increase security against hacking attempts by making it more challenging for brute force attacks.

- Choose phrases wisely to enhance security like avoiding terms such as "passwords" or "123456". Instead, opt for passphrases that blend words together for added protection.
- Utilize password managers. These applications assist in creating passwords. Securely storing them to alleviate the need for manual memorization of each one.
- Remember to update your passwords frequently. Refrain from using the ones on multiple platforms for enhanced security measures.

2. Enable Encryption (HTTPS/TLS)

Securing data transmission between your IoT devices and other network components relies heavily upon encryption. A safeguard that jumbles data to prevent unauthorized access and maintain privacy for personal information like financial records or sensitive business data.

To protect your network effectively, ensure its security measures are in place and working well. Encryption protocols such as HTTPS or TLS are crucial. The use of encryption helps secure the data transmitted over the web by making it indecipherable to hackers who may attempt to intercept it.

How to Activate Encryption

Make sure your device is compatible by confirming whether your IoT gadget is equipped with HTTPS/TLS encryption; a feature commonly found in device configurations.

- To adjust device settings, you can access them through the device's web interface or mobile application by navigating to the "*Security*" or "*Network*" sections.
- To enable HTTPS/TLS, search for "*encryption*" from settings. Turn on the option for *HTTPS* or *TLS* by either flipping a switch or checking a box.

Try out the connection by checking the encryption settings and then accessing the device using a browser. Make sure to look for "*https://*" in the URL to ensure a secure connection.

Enabling encryption greatly boosts your protection against cyber threats that aim at your devices on home networks.

3. Implement Two-Factor Authentication (2FA)

Two-factor authentication (2FA) is one of the best ways to protect your IoT devices from potential security breaches. This is a technique that is made of an extra layer of account safety which is usually a password and a second form of authentication. It requires the password the user knows, and also a second form of verification, for instance, an SMS code or QR code, which can be received through an authenticator application.

2FA Advantages

- **Extra Security Layer:** Passwords still are a must for IoT devices' protection. However, they can be compromised. 2FA makes passwords even harder to crack by requiring a second form of authentication, like a text message code, authentication app, or email confirmation.
- **Reduced Risk of Unauthorized Access:** Even if the hackers determine the password for your account, they will still be haunted by the second factor if you use it as well.

4. Regularly Update Software/Firmware

Ensuring that your software is always updated for security is a measure to protect your devices from potential hacker attacks. Manufacturers typically provide updates that contain fixes for known vulnerabilities that might otherwise be abused by individuals. Neglecting these updates can make your devices vulnerable to security risks, hence, jeopardizing the safety of your home network.

To make sure you don't give hackers any opportunities to exploit vulnerabilities in your system, security measures, and data privacy settings must be kept up to date. Software or firmware updates is a crucial task that you should stay on top of regularly.

- Enable automatic updates. Several IoT devices provide the choice for automatic update activation. When you turn this feature *ON*, it guarantees that the recent fixes are implemented without the need for involvement, therefore saving you time and energy.
- Make sure to check for updates if automatic updates are not an option, by establishing a routine schedule to do so regularly. This could involve accessing the device settings through its application or web interface.
- Continuously check the manufacturer's website to stay updated on the updates and installation instructions that are tailored to your device model.
- Watch for any email notifications or alerts, from device makers regarding updates or security fixes.

5. Restrict Network Access via Firewalls/Segmentation

Securing IoT devices is crucial for safeguarding your home or workplace environment through network security measures like segmenting your network into parts to prevent unauthorized access to connected devices. This ensures that in case of a breach in one area doesn't compromise all your devices simultaneously.

Firewalls play a role in enhancing the security of your network by providing an extra layer of protection. They act as a buffer—separating your network from threats and preventing malicious traffic while permitting genuine data exchanges. Several routers are equipped with built-in firewall functionalities that can be conveniently enabled for added security measures.

6. Disable Unnecessary Features

Disabling unnecessary functions in your devices can help reduce the chances of cyber attacks in IoT setups by shrinking potential areas that can be targeted by hackers' malicious activities. Several devices have configurations that include options such as control and Universal Plug and Play (UPnP). Although these functions aim to provide convenience to users, they also introduce weaknesses that malicious actors might take advantage of.

Managing your device remotely is quite convenient since it lets you control it from anywhere. However, it can pose a security risk when not properly secured. Having *UPnP* enables devices on the network to connect seamlessly but its automated function can create vulnerabilities for access.

- If you don't need to access your device remotely, simply switch off the remote management feature using the toggle option found in the settings menu.
- Make sure to review your router's settings and switch off UPnP if it's not essential for your configuration to avoid access to your network via this protocol.

7. Implement Hardware-Level Security Measures

Protecting your gadgets from cyber intrusions demands more than relying on software safeguards. It also involves implementing strong security measures at the hardware level. Some smart devices and sensors from manufacturers offer enhanced security features such as boot procedures and hardware-driven encryption to bolster their defenses further.

- **Secure Boot Procedures:** This system makes sure that reliable software gets started when the device boots up. The secure boot procedures verify the software's integrity to stop code from running and protect the device from firmware updates.
- **Hardware-Assisted Encryption:** By using the encryption functions integrated into devices' hardware components—this feature encrypts data directly at the hardware level, ensuring that sensitive information remains secure even if a hacker obtains physical access to the device.

8. Regularly Monitor/Audit Systems Activity

Keeping an eye on the actions of your devices is vital for safeguarding from possible dangers like cyber threats and breaches of security measures at home or in transmitting your data securely.

- By keeping an eye on things consistently detects any behavior early on and may prevent a hacking incident from causing major harm.

- By reviewing system logs, you can uncover information about how devices are functioning and the level of security in place. This can detect any unauthorized access or potential security breaches that may have occurred.

Tools and Software Choices

- Network monitoring tools such as Wireshark or Nagios provide real-time analysis of network traffic to help identify any occurrences.
- System log auditors, like Splunk or Loggly, help with managing logs to track device activities efficiently.
- Leveraging tools such as Cisco IoT Threat Defense offers a method to oversee and address security risks.

9. Secure Physical Access

Securing the surroundings of your gadgets is as important as implementing digital security protocols. Devices such as cameras are gateways that house confidential information that is susceptible to unauthorized access or tampering.

Approaches

- Use protective casings that are resistant to tampering.
- Add security features to enclosures to help prevent threats and deter unauthorized access or tampering with your devices.
- Place devices in easy-to-reach spots can help lower the chances of tampering or access control breaches. For example, mount surveillance cameras up high. Make sure entrances are inside areas away from windows and doors.

10. Examine Third-Party Services/Integrations

Ensuring the security of your network is essential. It's important to examine third-party services and integrations as they can be potential vulnerabilities in your security setup if not thoroughly assessed.

Before integrating a third-party service into your system or application environment, make sure to conduct security assessments on them. This involves verifying their compliance with industry certifications and familiarizing yourself with how they handle and protect data. Utilizing resources like the guidelines outlined in the NIST Special Publication 800 53 can serve as a foundation for carrying out these assessments.

It's important to be careful about trusting what vendors promise without verifying it yourself. What seems like a safe solution at first may bring in weaknesses over time. So, it's crucial to keep checking. Don't forget that overlooking this could lead to cybersecurity risks.

Make sure to check on these services even after you've first set them up. Get a look at updates and policy changes. Keep an eye out for any new security risks that could affect your overall security situation.

IOT NETWORK SECURITY

Concept	Description
IoT device constraints	IoT devices are deployed in massive quantities, and in many cases, they lack sufficient computational, storage, and power resources, which makes it challenging to implement advanced security features in these devices and makes them an easy target for hackers in many cases.
Siloed deployments	IoT devices come from different vendors, and each one has its own monitoring and management solution, making it difficult to apply common network and security settings to them.
Lack of common IoT standards	IoT devices have many architectures; companies follow different design models and layered concepts. This makes it challenging to apply a single unified security protocol and settings to them.
Zero trust	A cybersecurity concept that means no user or device should be trusted to access network resources without proper validation. This validation should be dynamic and continuous throughout the connectivity and can be updated at any time based on the user or device's current security posture.
Least privilege	A security concept that involves limiting users or devices to the minimum privileges and access necessary for them to perform their required tasks. This helps minimize potential damage from security attacks and improves the security and privacy of the network by granting access to data and resources only to those who need it. This access is also restricted to the operations they must perform as part of their assigned duties.
Network segmentation	A security practice that divides the network into multiple security segments or zones and controls access between segments. This control can range from total isolation (air gap), next-generation firewall (NGFW), or simply access control lists (ACL) between them. Network segmentation is not primarily intended to prevent attacks; rather, it helps limit the impact by restricting the lateral movement of hackers within the same segment, which can be confined to a single device (micro-segmentation).
Network access control (NAC)	A security tool that limits access to the network to authorized users and devices only and controls their privileges in the network. It achieves this typically by applying the AAA concept (Authentication, Authorization, and Accounting) to all users and devices that connect to the network.

Man-in-the-Middle-Attack (MITM)	A cybersecurity attack where the malicious actor intercepts the communication between two parties to steal confidential information or alter the data exchanged between them. MITM typically starts with a malicious user establishing a trust relationship with one or both parties and inserting himself into the conversation while both parties believe they are communicating directly with each other.
Botnet attack	A type of cybersecurity attack in which the malicious actor compromises and controls the victim devices—often referred to as bots or zombies remotely and establishes a command center to control them in a coordinated attack against targeted resources, commonly known as a distributed denial-of-service (DDoS) attack.

IoT network technology selection

IoT device constraints include limited power, storage, and processing capabilities. Organizations should consider these constraints as they source, deploy, and secure systems.

Key factors to consider include:

- **Range:** The distance the technology can effectively cover.
- **Speed:** The rate at which data can be transmitted.
- **Power consumption:** The amount of energy required for operation.
- **Cost:** The expenses associated with implementing and maintaining the technology.
- **Interference:** Susceptibility to disruptions from other devices or environmental factors.

Despite these constraints, IoT systems often generate massive volumes of data through various connected devices, including sensors, cameras, and smart appliances. These devices continually capture real-time data such as temperature, motion, health measurements, energy consumption, and additional metrics. With the increasing number of IoT devices, the scale and variety of data produced are growing exponentially, offering rich resources for AI and Machine Learning (ML) model training.

BYOD (Bring Your Own Device) policies and data leakage prevention

BYOD (Bring Your Own Device) refers to a policy where employees are allowed to use their **personal devices such as smartphones, laptops, and tablets** to access an organization's network, applications, and data. This approach improves flexibility and productivity but also introduces several **security risks**, especially related to **data leakage**. 

1. BYOD Policies

A **BYOD policy** is a set of rules and guidelines defined by an organization to ensure secure use of personal devices in the workplace.

Key components of a BYOD policy include:

- **Device Registration:** Employees must register their personal devices before connecting to the company network.

- **Security Requirements:** Devices should have strong passwords, screen locks, and updated operating systems.
- **Use of Security Software:** Installation of antivirus, firewall, or Mobile Device Management (MDM) tools.
- **Access Control:** Limit access to sensitive data based on user roles.
- **Remote Wipe Capability:** Ability to erase organizational data if the device is lost or stolen.
- **Acceptable Use Policy:** Guidelines on how employees can use their devices for work-related tasks.

2. Data Leakage in BYOD

Data leakage occurs when sensitive organizational information is **accidentally or intentionally exposed to unauthorized users** through personal devices.

Common causes of data leakage:

- Lost or stolen devices
- Use of unsecured public Wi-Fi networks
- Malware or malicious applications
- Sharing files through unauthorized apps or cloud services
- Weak authentication mechanisms

3. Data Leakage Prevention (DLP) Techniques

Organizations implement **Data Leakage Prevention (DLP)** strategies to protect sensitive information.

Important DLP methods include:

- **Encryption:** Protecting data stored on devices and during transmission.
- **Mobile Device Management (MDM):** Monitoring and controlling devices accessing the network.
- **Access Restrictions:** Limiting access to confidential data.
- **Secure VPN Usage:** Ensuring secure remote connections.
- **Regular Security Updates:** Keeping devices patched and updated.
- **Employee Awareness Training:** Educating users about cyber security risks.